LABORATUVAR 2 · MİRKA SMART WOODSANDER 5000 · Ahşap Zımpara Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad: _____ Grup: _____ Tarih: ___/___/2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. Conduit = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi: Üretim PLC · Emniyet PLC'si · HMI (port 80 web arayüzü!) · zımpara kafası/besleme sürücüleri · internete açık uzak bakım modülü · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · “admin/admin” servis hesabı

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

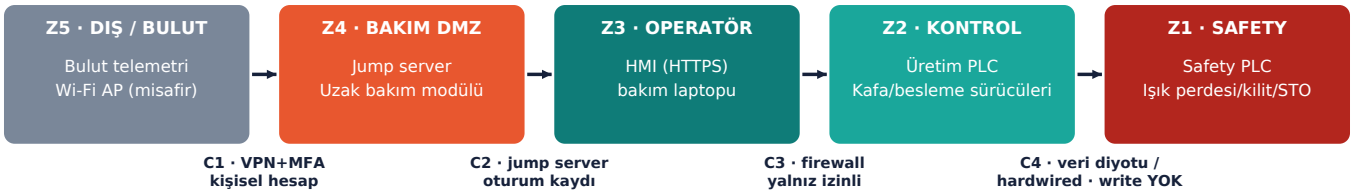
- **Z1 Safety Zone:** Emniyet PLC'si (+ ışık perdesi, kapak kilidi, STO — en kritik, en az bağlantı).
- **Z2 Kontrol Zone:** Üretim PLC, zımpara kafası/besleme motor sürücüleri.
- **Z3 Operatör Zone:** HMI (port 80 → HTTPS'e alınmalı/erişim kısıtlanmalı), bakım laptopu.
- **Z4 Bakım DMZ:** jump server, uzak bakım modülü, servis hesapları (kişiselleştirilmiş). 2 USB portu: fiziksel kilit/devre dışı, yalnız kontrollü bakım istasyonundan.
- **Z5 Dış/Bulut Zone:** bulut telemetri, Wi-Fi AP (misafir/ayrı ağ, kontrol ağına yolu yok).

2 Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

İnternet ile makine arasında köprü olduğu için **Z4 (DMZ)** sınırında yer alır. **Bugünkü haliyle (internete doğrudan açık, kontrol ağıyla düz bağlantı) kalamaz**: doğrudan internetten Z2/Z1'e uzanan tek hatadır; bir ele geçirme, zımpara kafası sürücülerine ve Safety PLC'ye kadar gider. Kalabilmesi için: DMZ'ye taşınmalı, jump server arkasına alınmalı, VPN+MFA, varsayılan kapalı olmalı.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

- **C1 İnternet/Z5 → Z4:** VPN, MFA, kişisel hesap, IP/zaman kısıtı.
- **C2 Z4 → Z3/Z2:** yalnız jump server üzerinden; tam oturum kaydı; yalnız izinli protokol/komut.
- **C3 Z3 → Z2:** firewall; sadece HMI→PLC gerekli portlar; HMI'dan Safety'ye yol yok.
- **C4 Z2 → Z1:** tek yönlü/izlenen; **Safety PLC'ye uzaktan yazma yok**; konfigürasyon yalnız yerinde, anahtarla (fiziksel erişim) ve imzalı olarak.
- Bulut telemetri: yalnızca **çıkış yönlü, salt-okunur** veri; komut girişi kapalı.



İnternet → Z5 → Z4 → Z3 → Z2 → Z1 : içe doğru gittikçe kritiklik artar, her geçişte bir kapı vardır. Safety PLC'ye uzaktan yazma yolu yoktur.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tek denetim noktası; makineye doğrudan erişim yok, her oturum izlenir.
Tünel?	Açık / VPN	**VPN** — açık port yok; trafik şifreli, saldırı yüzeyi küçük.
Kimlik?	Parola / MFA	**MFA** — çalınan/zayıf parola (admin/admin gibi) tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kim, ne zaman, ne yaptı izlenebilir; kişi ayrılınca hesap kapanır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — olay incelemesi ve CRA kanıtı için şart.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — yalnız onaylı bakım penceresinde açılır, bitince kapanır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.